SecureDT - Security Guide

CSRF, rate limits, headers, audit logging and safe attack labs

Runtime protections applied to every request:

- CSRF token validation on all state-changing API calls (token obtained from /api/state)
- Per-IP rate limiting with 429 responses
- Security headers: X-Frame-Options, CSP, nosniff, referrer-policy, HSTS (HTTPS)
- Hardened JSON error envelope - no stack traces leaked
- Upload validation: CSV only, size + row caps
- Sessions signed with a per-process SECRET_KEY

Application Security lab

/application-security runs a live posture check (11 checks) and grades the result A-F.

Audit log

The engine.audit_log module records INFO / WARNING / SECURITY / ERROR / AUDIT events in memory and appends to a CSV on disk. /audit-logs exposes the live feed with category filter and export.

Attack lab safety

All attacks are simulated inside the digital twin and virtual storages; nothing touches your network or machine. Mitigation quarantines the node and raises integrity/risk counters for demos only.